

Threat-Led Penetration Testing (TLPT) Reports

Document ID	Version	Owner	Effective Date	Framework	Classification
[TLPT-REPORT-ID]	1.0	[Head of Cyber Resilience / CISO]	[DD MMM YYYY]	DORA	Strictly Confidential - Restricted Distribution

Purpose

This report documents the planning, execution, results and remediation actions arising from the Threat-Led Penetration Testing (TLPT) exercise conducted for [Organisation Name].

The purpose of the TLPT was to assess, under controlled and intelligence-led conditions, the organisation’s ability to withstand, detect, respond to and recover from realistic cyber-attacks targeting critical or important business services. The exercise was designed to emulate the tactics, techniques and procedures of credible threat actors relevant to [Organisation Name], using current threat intelligence and a risk-based testing approach aligned with recognised European TLPT methodology.

This report provides:

- A record of the agreed TLPT scope, objectives, rules of engagement and testing timeline.
- A summary of the threat intelligence and attack scenarios used to drive testing.
- Evidence-based findings on technical weaknesses, process gaps and resilience limitations.
- An assessment of detection, response, escalation and recovery performance.
- Root cause analysis and risk implications for critical or important functions.
- Prioritised remediation actions, owners and target completion dates.
- Information required to support management oversight, regulatory engagement and audit review.

This document is intended for senior management, accountable control owners, cyber resilience leadership, internal assurance functions and relevant supervisory stakeholders where required. It must be handled as highly sensitive security information.

Reporting Period & Scope

Reporting Period

Item	Detail
Reporting period covered	[DD MMM YYYY] to [DD MMM YYYY]
TLPT planning start date	[DD MMM YYYY]
Threat intelligence phase	[DD MMM YYYY] to [DD MMM YYYY]
Red team testing phase	[DD MMM YYYY] to [DD MMM YYYY]
Purple team / replay phase	[DD MMM YYYY] to [DD MMM YYYY]
Draft report issued	[DD MMM YYYY]
Final report approved	[DD MMM YYYY]
Previous TLPT date	[DD MMM YYYY / Not applicable]
Next scheduled TLPT cycle	No later than [DD MMM YYYY]

Scope Overview

The TLPT focused on critical or important business services whose disruption, compromise or unauthorised manipulation could materially affect customers, counterparties, market participants, financial stability, regulatory obligations or the organisation's operational resilience.

Scope Area	Included in TLPT	Notes
Critical or important functions	Yes	[List key business functions]
Production systems	Yes	Controlled testing only, subject to agreed safeguards
Corporate network	Yes	In scope for initial access, lateral movement and privilege escalation
Cloud environments	[Yes/No]	[Cloud platforms and regions]
Internet-facing infrastructure	Yes	Reconnaissance, exploitation attempts and access validation
Identity and access management	Yes	Authentication, privilege escalation, federation and directory services
Security monitoring and response	Yes	Detection, triage, escalation and incident handling assessed
Third-party ICT service providers	[Yes/No/Partial]	[Provider names or service categories]
Social engineering	[Yes/No/Partial]	[Phishing, vishing, physical entry, or excluded]
Physical security testing	[Yes/No]	[Sites and constraints]
Data exfiltration simulation	Yes	Simulated and controlled, no unauthorised extraction of live sensitive data
Destructive testing	No	Explicitly prohibited
Denial-of-service testing	No	Explicitly prohibited unless separately authorised

In-Scope Critical or Important Services

Service / Function	Business Owner	Supporting Systems	Business Impact if Disrupted	Included Attack Objective
[Payment processing service]	[Owner]	[Systems]	Delayed or failed customer payments, settlement impact	Gain unauthorised access to payment workflow or administrator function
[Trading / transaction platform]	[Owner]	[Systems]	Market or client impact, financial loss, regulatory notification	Compromise privileged access or manipulate transaction flow
[Customer digital channel]	[Owner]	[Systems]	Customer service outage, account compromise risk	Obtain access to customer data or application administration
[Core banking / ledger service]	[Owner]	[Systems]	Integrity risk to balances, reporting and reconciliation	Demonstrate ability to alter or access sensitive records
[Operational support function]	[Owner]	[Systems]	Reduced ability to operate or recover services	Compromise support tooling or backup administration

Out-of-Scope Items

The following items were excluded to maintain safety, legal compliance and operational stability:

- Destructive malware deployment.
- Uncontrolled denial-of-service activity.
- Encryption, deletion or corruption of production data.
- Unauthorised access to customer accounts beyond approved test identities.
- Persistence mechanisms that could survive beyond the test window without explicit approval.
- Exfiltration of live personal, financial or regulated data.
- Testing against third-party systems not covered by legal permission or a signed authorisation.

- Any activity outside the approved rules of engagement and escalation paths.

Participants and Roles

Role	Organisation / Team	Named Lead	Responsibility
Senior accountable executive	[Organisation Name]	[Name]	Executive sponsorship and acceptance of residual risk
TLPT control team	[Organisation Name]	[Name]	Overall coordination, safety control and stakeholder management
Threat intelligence provider	[Provider Name]	[Name]	Threat landscape analysis and scenario development
Red team provider	[Provider Name]	[Name]	Controlled execution of attack simulations
Blue team / SOC	[Organisation Name / Provider]	[Name]	Monitoring, detection, triage and response
ICT operations	[Organisation Name]	[Name]	System support, safety monitoring and remediation input
Business service owners	[Organisation Name]	[Names]	Impact validation and risk treatment ownership
Legal and compliance	[Organisation Name]	[Name]	Legal authorisation, regulatory considerations and evidence review
Internal audit / assurance	[Organisation Name]	[Name]	Independent review and action tracking, where applicable

Executive Summary

The TLPT exercise provided a realistic assessment of [Organisation Name]'s cyber resilience against threat actors likely to target financial entities and their critical technology dependencies. The test used current threat intelligence to emulate plausible adversary behaviour, including external reconnaissance, credential harvesting, exploitation of exposed services, lateral movement, privilege escalation, evasion of monitoring and attempted access to systems supporting critical or important services.

Overall, the exercise demonstrated that [Organisation Name] has established foundational capabilities for security monitoring, incident handling and access control. However, the TLPT identified material weaknesses that could allow a capable adversary to gain a foothold, move across parts of the environment, escalate privileges and reach systems supporting critical business services under certain conditions.

The most significant risks identified were:

- Incomplete detection coverage for identity-based attack techniques.
- Excessive privileges and weak segmentation between corporate and production support environments.
- Inconsistent hardening and patching of externally exposed and internally reachable systems.
- Insufficient monitoring of administrative tooling and service accounts.
- Delays in escalation from technical alerts to business impact assessment.
- Gaps in third-party access oversight and logging integration.
- Limited rehearsal of decision-making for a stealthy, multi-stage intrusion.

Overall Result

Assessment Area	Result	Summary
Prevention and attack surface reduction	Partially effective	External exposure was generally managed, but exploitable weaknesses and misconfigurations remained.

Assessment Area	Result	Summary
Identity and access control	Needs improvement	Credential misuse and privilege escalation paths were demonstrated.
Network segmentation	Needs improvement	Segmentation did not consistently prevent movement toward sensitive environments.
Security monitoring and detection	Partially effective	Some activity was detected, but several high-risk techniques were missed or not prioritised.
Incident response and escalation	Partially effective	SOC triage was timely for some alerts, but escalation to crisis and business stakeholders was inconsistent.
Data protection controls	Partially effective	Data access was restricted in key systems, but monitoring of simulated exfiltration paths was incomplete.
Operational resilience	Partially effective	Recovery capabilities exist, but playbooks did not fully reflect the tested attack scenarios.

Key Findings Summary

Ref	Finding Title	Severity	Primary Risk Area	Status
F-01	Insufficient monitoring of identity attack techniques	High	Detection and response	Open
F-02	Excessive standing privileges for administrative accounts	High	Access management	Open
F-03	Lateral movement possible between corporate and support environments	High	Network segmentation	Open
F-04	Weaknesses in third-party remote access controls	High	Third-party ICT risk	Open
F-05	Externally exposed service vulnerable to credential-based compromise	Medium	Attack surface management	Open
F-06	Security alerts not consistently linked to critical service impact	Medium	Incident management	Open
F-07	Incomplete logging coverage for privileged service accounts	Medium	Monitoring and accountability	Open
F-08	Backup and recovery administration not sufficiently isolated	Medium	Resilience and recovery	Open
F-09	Phishing reporting process effective but response automation incomplete	Low	User reporting and SOC workflow	Open
F-10	Incident communications templates not tailored to TLPT scenarios	Low	Crisis communications	Open

Management Conclusion

The TLPT achieved its objectives and produced actionable evidence on the organisation's ability to withstand and respond to realistic cyber-attacks. No uncontrolled service disruption occurred during testing. The findings require coordinated remediation across cyber security, infrastructure, identity management, third-party management, operations and business resilience teams.

The priority for management is to reduce the likelihood of privileged compromise, strengthen segmentation around critical services, improve monitoring of identity and administrative activity, and ensure that incident escalation processes rapidly connect technical indicators to potential business service impact.

Methodology

Approach

The TLPT was conducted using an intelligence-led and risk-based approach consistent with recognised European threat-led testing practices. The methodology followed a controlled sequence from scoping and threat intelligence through to red team execution, detection review, debriefing and remediation planning.

The exercise was designed to balance realism with safety. Testing activities were authorised in advance, subject to legal permission, restricted by rules of engagement and monitored by the TLPT control team.

Methodology Phases

Phase	Description	Key Outputs
Initiation and governance	Established sponsorship, test objectives, legal authorisation, roles and safety controls.	Approved scope, rules of engagement, contact tree, risk acceptance for testing.
Scoping	Identified critical or important services, supporting assets, third-party dependencies and testing constraints.	Scope specification, service dependency map, exclusions.
Threat intelligence	Analysed relevant threat actors, targeting patterns, tactics, tools and sector-specific attack paths.	Targeted threat intelligence report and proposed attack scenarios.
Scenario design	Converted threat intelligence into realistic attack objectives and test plans.	Approved attack scenarios and success criteria.
Red team execution	Conducted controlled adversary emulation against agreed targets.	Evidence of achieved objectives, attack narrative and technical artefacts.
Detection and response assessment	Reviewed how alerts, incidents and escalations were handled by the blue team and supporting functions.	Detection timeline, missed opportunities, response effectiveness assessment.
Replay / purple team review	Shared selected techniques with defenders to validate detection improvements and learning points.	Detection tuning recommendations and validated control improvements.
Reporting and remediation planning	Consolidated findings, risk ratings, root causes and actions.	Final TLPT report, remediation plan and management summary.

Rules of Engagement

The following rules governed execution:

- All testing was limited to approved dates, times, systems, scenarios and providers.
- The TLPT control team maintained authority to pause, modify or terminate testing at any time.
- Emergency contacts were available throughout active testing windows.
- Red team activity was logged and evidence was retained securely.
- Any discovery of actual malicious activity or operational instability was to be escalated immediately.
- No destructive actions, uncontrolled malware, unauthorised persistence or live sensitive data exfiltration were permitted.
- Testing of third-party ICT providers was performed only where appropriate authorisation and coordination were in place.
- Evidence collection was limited to what was necessary to demonstrate risk and support remediation.
- Production impact safeguards were applied to prevent material disruption to critical or important services.

Attack Objectives

Objective ID	Attack Objective	Business Relevance	Outcome
AO-01	Gain an initial foothold through externally available services or credential compromise.	Tests exposure to common entry points used by financial sector adversaries.	Achieved
AO-02	Establish persistence sufficient to maintain access during the test window.	Tests endpoint controls and monitoring of suspicious access patterns.	Partially achieved
AO-03	Escalate privileges within the corporate environment.	Tests identity governance, privileged access and administrative hygiene.	Achieved
AO-04	Move laterally toward systems supporting [critical service].	Tests segmentation, monitoring and access control boundaries.	Achieved
AO-05	Access sensitive data stores or administration consoles.	Tests data protection and privileged activity monitoring.	Partially achieved
AO-06	Simulate exfiltration of sensitive information without transferring live sensitive data.	Tests monitoring of outbound traffic and data loss indicators.	Partially achieved
AO-07	Trigger and assess detection, triage, escalation and response.	Tests cyber incident operating model and service impact assessment.	Partially achieved

Severity Rating Method

Findings were rated using a risk-based severity model that considered:

- Likelihood of exploitation by a capable threat actor.
- Potential impact on critical or important services.
- Degree of access or privilege obtained.
- Ease of replication.
- Availability of compensating controls.
- Detection and response effectiveness.
- Exposure of customer, financial, operational or regulated data.
- Potential for propagation across environments or third-party connections.

Severity	Definition	Expected Treatment
Critical	A weakness that could plausibly enable material compromise or disruption of a critical or important service with limited effort, or where active exploitation is suspected.	Immediate containment, executive notification and urgent remediation.
High	A weakness that could enable significant unauthorised access, privilege escalation, service impact or data exposure.	Prioritised remediation with senior management oversight.
Medium	A weakness that increases attack success likelihood or reduces detection and response effectiveness but requires additional conditions to cause major impact.	Planned remediation with accountable owner and target date.
Low	A weakness with limited direct impact, usually relating to process maturity, documentation, tuning or efficiency.	Address through continuous improvement or scheduled control enhancement.

Detailed Findings / Results (with structure)

Finding F-01 - Insufficient Monitoring of Identity Attack Techniques

Attribute	Detail
Severity	High
Status	Open
Affected areas	Identity platform, SOC monitoring, privileged access management
Business impact	Increased likelihood that an attacker could compromise accounts, escalate privileges and access critical service support systems without timely detection.
Evidence source	Red team activity logs, SIEM review, SOC ticket analysis

Observation

The red team successfully performed credential misuse and identity-based attack techniques that were not consistently detected or prioritised. Activities included abnormal authentication patterns, use of compromised credentials from unusual locations, enumeration of directory objects and attempts to access privileged resources.

Several indicators were visible in source logs but were not correlated into actionable alerts or were assigned low priority.

Evidence

Evidence Item	Description	Result
E-01	Unusual authentication attempts using test credentials	Logged but not escalated
E-02	Directory enumeration activity	Not detected
E-03	Privilege discovery commands	Not alerted
E-04	Access attempts to administrative groups	Partially detected
E-05	Impossible travel / anomalous login pattern simulation	Alerted but triaged as low priority

Root Cause

- Identity threat detection use cases are incomplete.
- Correlation rules do not adequately combine authentication, endpoint and privilege events.
- SOC runbooks do not clearly define escalation thresholds for identity compromise indicators.
- Privileged access events are not consistently enriched with business service context.

Risk

A capable adversary could use stolen or abused credentials to progress from initial access to higher-value systems before the organisation recognises the compromise.

Finding F-02 - Excessive Standing Privileges for Administrative Accounts

Attribute	Detail
Severity	High
Status	Open
Affected areas	Privileged access management, directory services, infrastructure administration
Business impact	Increased risk of rapid escalation from compromised administrator accounts to systems supporting critical or important services.
Evidence source	Account review, privilege escalation path analysis, red team execution records

Observation

The test identified administrative accounts with broad standing privileges across multiple environments. Some accounts had access not aligned to current job responsibilities or service ownership. In several cases, administrative access was not time-bound, subject to step-up authentication or restricted to hardened administration workstations.

Evidence

Evidence Item	Description	Result
E-06	Administrative account with access across corporate and production support tools	Confirmed
E-07	Privileged group membership not reviewed within expected cycle	Confirmed
E-08	Service administrator access available without just-in-time approval	Confirmed
E-09	Administrative session not fully recorded	Confirmed

Root Cause

- Privilege reviews are not sufficiently risk-based.
- Legacy administrative models remain in use.
- Just-in-time access is not consistently implemented.
- Ownership of privileged groups is not clearly assigned for all environments.

Risk

If an administrative account is compromised, the attacker may be able to move quickly across systems and gain control over sensitive infrastructure or service management functions.

Finding F-03 - Lateral Movement Possible Between Corporate and Support Environments

Attribute	Detail
Severity	High
Status	Open
Affected areas	Network segmentation, endpoint management, service administration
Business impact	Increased risk that compromise of a lower-trust environment could be used to reach systems supporting critical services.
Evidence source	Network path testing, firewall rule review, red team logs

Observation

The red team demonstrated viable movement paths from the corporate environment into support networks used to administer sensitive services. While direct access to some production systems was restricted, management interfaces and intermediary systems were reachable under conditions that could be abused by a capable attacker.

Evidence

Evidence Item	Description	Result
E-10	Reachability from corporate workstation segment to support service	Confirmed

Evidence Item	Description	Result
E-11	Management protocol accessible from broader network range than required	Confirmed
E-12	Jump host controls present but bypass path identified	Confirmed
E-13	Segmentation alerting on denied or unusual access	Limited

Root Cause

- Firewall rules include legacy allowances.
- Segmentation standards are not consistently enforced for support tooling.
- Network access reviews are not linked to critical service dependency maps.
- Monitoring of east-west traffic is limited.

Risk

An attacker who compromises a corporate endpoint may be able to reach administration paths for sensitive environments and increase the likelihood of operational disruption or data exposure.

Finding F-04 - Weaknesses in Third-Party Remote Access Controls

Attribute	Detail
Severity	High
Status	Open
Affected areas	Third-party ICT access, vendor management, remote access gateways
Business impact	Increased risk that a third-party compromise could be used to access systems supporting critical or important services.
Evidence source	Access configuration review, red team scenario, vendor access logs

Observation

The TLPT identified weaknesses in the governance and monitoring of remote access used by third-party ICT service providers. Some access paths lacked sufficient session monitoring, business justification, time limitation or integration into central security monitoring.

Evidence

Evidence Item	Description	Result
E-14	Third-party access available outside approved support window	Confirmed
E-15	Session recording not enabled for selected vendor access path	Confirmed
E-16	Vendor account not linked to named individual in all cases	Confirmed
E-17	Remote access logs not fully ingested into SIEM	Confirmed

Root Cause

- Third-party access controls vary by platform and provider.
- Vendor onboarding standards have not been fully applied to legacy access methods.

- Central monitoring requirements are not consistently enforced.
- Periodic recertification of vendor access lacks technical validation.

Risk

A compromised third-party account or provider environment could provide an attacker with a trusted route into the organisation.

Finding F-05 - Externally Exposed Service Vulnerable to Credential-Based Compromise

Attribute	Detail
Severity	Medium
Status	Open
Affected areas	Internet-facing infrastructure, authentication controls
Business impact	Increased likelihood of initial access through externally exposed services.
Evidence source	External reconnaissance, authentication testing, red team logs

Observation

The red team identified an externally accessible service that allowed repeated authentication attempts without sufficient adaptive controls. Although multi-factor authentication was present, risk-based challenge behaviour and monitoring were not consistently triggered.

Evidence

Evidence Item	Description	Result
E-18	External service identified through open-source reconnaissance	Confirmed
E-19	Repeated login attempts using test accounts	Allowed within test threshold
E-20	Adaptive authentication not triggered for all anomalous patterns	Confirmed
E-21	SOC alert generated only after extended activity	Confirmed

Root Cause

- Authentication thresholds are not consistently tuned across exposed services.
- External attack surface monitoring is not fully integrated with identity monitoring.
- Risk-based authentication policies are not uniformly applied.

Risk

Attackers may use password spraying, credential stuffing or targeted credential attacks to obtain access before detection or lockout controls become effective.

Finding F-06 - Security Alerts Not Consistently Linked to Critical Service Impact

Attribute	Detail
Severity	Medium

Attribute	Detail
Status	Open
Affected areas	SOC, incident management, operational resilience
Business impact	Delayed recognition of potential impact to critical or important services during an intrusion.
Evidence source	SOC ticket review, escalation timeline, interviews

Observation

During the exercise, several alerts were investigated as isolated technical events rather than as part of a potential multi-stage attack against a critical business service. SOC analysts did not consistently have access to service dependency information or predefined escalation triggers for critical service impact.

Evidence

Evidence Item	Description	Result
E-22	Alert involving system linked to critical service support chain	Not escalated as business-impacting
E-23	Dependency map unavailable in SOC workflow	Confirmed
E-24	Incident severity based primarily on technical indicator	Confirmed
E-25	Business owner notification delayed	Confirmed

Root Cause

- Service dependency data is not integrated into security operations tooling.
- Incident classification does not sufficiently account for business service criticality.
- Escalation runbooks are not scenario-specific for stealthy intrusions.

Risk

An incident affecting a critical or important service could remain under-classified, delaying management decisions, containment and recovery actions.

Finding F-07 - Incomplete Logging Coverage for Privileged Service Accounts

Attribute	Detail
Severity	Medium
Status	Open
Affected areas	Service accounts, logging, SIEM monitoring
Business impact	Reduced ability to detect and investigate misuse of privileged service accounts.
Evidence source	Logging configuration review, SIEM validation, account inventory

Observation

Several privileged service accounts used by key platforms were not covered by complete logging, alerting or behavioural baselining. In some cases, authentication logs were collected but command execution, configuration changes or access to sensitive objects were not centrally monitored.

Evidence

Evidence Item	Description	Result
E-26	Service account authentication visible in source system	Confirmed
E-27	Service account activity not fully forwarded to SIEM	Confirmed
E-28	No baseline for expected service account behaviour	Confirmed
E-29	Ownership metadata incomplete	Confirmed

Root Cause

- Service account inventory is incomplete.
- Logging standards do not specify minimum events for privileged non-human accounts.
- Control ownership between application and infrastructure teams is unclear.

Risk

Misuse of service accounts could remain undetected, allowing stealthy access to systems and data.

Finding F-08 - Backup and Recovery Administration Not Sufficiently Isolated

Attribute	Detail
Severity	Medium
Status	Open
Affected areas	Backup platforms, recovery administration, resilience controls
Business impact	Increased risk that an attacker could weaken recovery capability during a cyber incident.
Evidence source	Access path review, backup administration configuration, interviews

Observation

The test identified administration paths to backup and recovery tooling that were not fully isolated from standard administrative environments. While backup data protection controls exist, management access controls could be strengthened to reduce the risk of attacker interference.

Evidence

Evidence Item	Description	Result
E-30	Backup administration console reachable from support network	Confirmed
E-31	Privileged backup role assigned to standing account	Confirmed
E-32	Administrative access not restricted to hardened workstation	Confirmed
E-33	Recovery playbook does not include privileged compromise scenario	Confirmed

Root Cause

- Backup administration controls were designed for operational convenience rather than adversary resistance.
- Isolation requirements for recovery tooling are not fully embedded in architecture standards.

- Recovery exercises have not sufficiently tested cyber compromise of administrators.

Risk

An attacker with elevated access may be able to impair restoration capability, increasing the impact and duration of a cyber incident.

Finding F-09 - Phishing Reporting Process Effective but Response Automation Incomplete

Attribute	Detail
Severity	Low
Status	Open
Affected areas	User reporting, email security, SOC workflow
Business impact	Good user reporting reduces dwell time, but incomplete automation may slow containment during high-volume events.
Evidence source	Social engineering simulation, SOC tickets, user reporting metrics

Observation

Users reported simulated phishing messages through the approved reporting channel. However, automated enrichment, mailbox search and removal actions were not consistently triggered, requiring manual SOC effort.

Evidence

Evidence Item	Description	Result
E-34	Users reported simulated phishing emails	Confirmed
E-35	SOC mailbox triage performed	Confirmed
E-36	Automated search and purge not triggered for all messages	Confirmed
E-37	User feedback notifications inconsistent	Confirmed

Root Cause

- Automation playbooks are not fully deployed across all email paths.
- Triage workflow relies on manual analyst actions.
- User feedback process is not standardised.

Risk

During a real campaign, manual handling could delay containment and increase exposure.

Finding F-10 - Incident Communications Templates Not Tailored to TLPT Scenarios

Attribute	Detail
Severity	Low
Status	Open
Affected areas	Incident communications, crisis management, stakeholder reporting

Attribute	Detail
Business impact	Potential inconsistency or delay in management communications during a complex cyber incident.
Evidence source	Tabletop discussion, response documentation review

Observation

Incident communication templates exist but do not fully address stealthy, multi-stage intrusions affecting critical or important services. Draft messages did not consistently include business service impact, customer implications, third-party involvement, regulatory decision points and recovery status.

Evidence

Evidence Item	Description	Result
E-38	Cyber incident communication template available	Confirmed
E-39	Critical service impact field absent	Confirmed
E-40	Third-party dependency section absent	Confirmed
E-41	Regulatory decision log not embedded	Confirmed

Root Cause

- Communication templates were developed for general cyber incidents.
- Operational resilience and cyber incident management documentation are not fully integrated.
- Scenario-based communications rehearsal has been limited.

Risk

Senior management may not receive timely, complete and consistent information during an actual incident.

Analysis

Attack Path Analysis

The TLPT demonstrated that a plausible attack path exists from initial access to sensitive support environments under certain conditions. The path required several weaknesses to be combined, but the combination was realistic for a capable adversary targeting a financial entity.

Stage	Red Team Activity	Control Performance	Key Gap
Reconnaissance	Identified exposed services, employee information and technology indicators.	Public exposure was partly managed.	External attack surface monitoring not fully comprehensive.
Initial access	Used credential-based techniques against approved targets.	Some controls limited access attempts.	Adaptive authentication and alerting inconsistent.
Establish foothold	Simulated persistence on approved test host.	Endpoint controls generated limited signals.	Alert correlation did not clearly identify persistence behaviour.
Privilege escalation	Identified and used excessive administrative permissions.	Some privileged actions required additional controls.	Standing privileges remained available.
Lateral movement	Moved toward support environments.	Segmentation blocked some direct routes.	Legacy access paths remained exploitable.
Target access	Reached systems supporting critical or important services.	Direct sensitive data access was restricted in several systems.	Administration and service account monitoring incomplete.
Simulated exfiltration	Conducted controlled data staging and exfiltration simulation.	Some outbound monitoring operated as expected.	Detection of low-volume and staged exfiltration incomplete.

Stage	Red Team Activity	Control Performance	Key Gap
Response	SOC investigated selected alerts.	Analysts identified some suspicious events.	Escalation to service impact and executive decision-making delayed.

Detection and Response Timeline

Time / Date	Event	Expected Response	Actual Response	Assessment
[DD MMM HH:MM]	Unusual authentication activity begins	Alert, correlate and monitor for credential attack	Logged; no immediate escalation	Needs improvement
[DD MMM HH:MM]	Directory enumeration performed	Alert and investigate identity compromise	Not detected	Needs improvement
[DD MMM HH:MM]	Privilege discovery activity observed	Alert and link to suspicious authentication	Not correlated	Needs improvement
[DD MMM HH:MM]	Lateral movement attempt to support environment	Network and endpoint alerts reviewed	Partially detected	Partially effective
[DD MMM HH:MM]	Access attempt to system supporting critical service	Escalate to incident manager and business owner	Escalation delayed	Needs improvement
[DD MMM HH:MM]	Simulated data staging activity	Detect and initiate containment decision	Not prioritised	Needs improvement
[DD MMM HH:MM]	SOC opens incident ticket	Assign severity based on technical and business impact	Severity initially too low	Partially effective
[DD MMM HH:MM]	Control team ends active scenario	Preserve evidence and conduct debrief	Completed	Effective

Control Effectiveness Assessment

Control Domain	Effectiveness	Supporting Observations
Asset and service understanding	Partially effective	Critical services were known, but dependency information was not readily usable by SOC analysts.
Threat intelligence use	Effective	Intelligence was relevant and successfully translated into realistic attack scenarios.
External attack surface management	Partially effective	Exposure was mostly understood, but authentication risk controls required improvement.
Vulnerability and configuration management	Partially effective	Known processes exist, but configuration drift and legacy access paths remain.
Identity and privileged access	Needs improvement	Excessive privileges and incomplete monitoring were central to the successful attack path.
Network segmentation	Needs improvement	Segmentation reduced some exposure but did not consistently prevent lateral movement.
Endpoint security	Partially effective	Some suspicious behaviour was visible but not reliably prioritised.
Logging and monitoring	Needs improvement	Log coverage and correlation gaps limited early detection.
Incident response	Partially effective	Technical triage occurred, but business escalation and scenario-specific decision-making lagged.
Third-party ICT risk management	Needs improvement	Remote access governance and monitoring require strengthening.
Backup and recovery resilience	Partially effective	Recovery capability exists, but administration paths require stronger isolation.

Business Impact Analysis

The TLPT did not cause material operational disruption. However, if the demonstrated attack path were executed by a real adversary without test constraints, the potential impacts could include:

- Unauthorised access to systems supporting critical or important services.

- Manipulation or interruption of operational workflows.
- Exposure of sensitive customer, transaction, employee or operational data.
- Loss of confidence from customers, counterparties and regulators.
- Delayed incident containment due to incomplete detection and escalation.
- Impaired recovery if backup administration were compromised.
- Increased dependency on manual processes during containment and restoration.
- Potential notification obligations depending on the nature, scale and impact of the incident.

Root Cause Themes

The findings show recurring themes rather than isolated control failures:

• Identity is the primary attack path

The most significant risk arises from credential misuse, excessive privilege and incomplete monitoring of identity events.

• Critical service context is not embedded in security operations

SOC workflows do not consistently present business service criticality, dependency relationships or escalation triggers.

• Legacy access paths weaken segmentation

Historical firewall rules, support paths and third-party access arrangements remain in place beyond current operational need.

• Privileged operations require stronger isolation

Administrative workstations, just-in-time access, session monitoring and service account controls are not yet consistent.

• Detection exists but lacks correlation and prioritisation

Logs are available in several source systems, but the organisation does not consistently convert them into high-confidence alerts.

• Third-party ICT access requires tighter oversight

Vendor access paths need stronger governance, logging, monitoring and periodic technical validation.

Overall Maturity View

Capability	Current State	Target State
TLPT governance	Structured and controlled	Repeatable three-year cycle with integrated remediation tracking
Threat-led testing	Established for this cycle	Embedded into broader resilience testing programme
Detection engineering	Developing	Threat-informed, measurable and continuously tuned
Privileged access management	Inconsistent across environments	Just-in-time, least privilege and fully monitored
Service-based incident response	Emerging	Critical service context embedded in triage and escalation

Capability	Current State	Target State
Third-party access assurance	Partially implemented	Centrally governed, monitored and regularly recertified
Recovery resilience	Documented	Tested against privileged compromise and cyber destruction scenarios

Recommendations & Actions

Remediation Principles

Remediation should be risk-based and prioritised according to the potential impact on critical or important services. Actions should address root causes, not only the individual test artefacts. Evidence of completion should be retained for audit, management review and future TLPT planning.

The following principles apply:

- Prioritise closure of high-severity findings.
- Treat identity, privileged access and segmentation as immediate risk reduction areas.
- Embed critical service context into SOC tooling and incident workflows.
- Validate remediation through retesting or purple team exercises.
- Ensure third-party access improvements are contractually and technically enforceable.
- Track all actions through the organisation's risk and control management process.
- Report overdue high-risk actions to senior management.

Action Plan

Action ID	Related Finding	Action	Owner	Target Date	Priority	Evidence Required	Status
A-01	F-01	Implement enhanced detection use cases for credential misuse, directory enumeration, privilege discovery and anomalous administrative access.	[SOC Manager]	[DD MMM YYYY]	High	SIEM rule list, test results, alert evidence	Open
A-02	F-01, F-06	Integrate critical service dependency information into SOC triage workflows and alert enrichment.	[Head of Cyber Operations]	[DD MMM YYYY]	High	Updated workflow, screenshots, test ticket evidence	Open
A-03	F-02	Remove unnecessary standing privileges and implement just-in-time access for high-risk administrative roles.	[Identity and Access Owner]	[DD MMM YYYY]	High	Access review sign-off, privileged access configuration, sample approvals	Open

Action ID	Related Finding	Action	Owner	Target Date	Priority	Evidence Required	Status
A-04	F-02	Require step-up authentication and hardened administration workstations for privileged access to critical service support systems.	[Infrastructure Security Owner]	[DD MMM YYYY]	High	Configuration evidence, access logs, exception register	Open
A-05	F-03	Review and restrict network paths between corporate, support and sensitive environments based on least privilege.	[Network Security Owner]	[DD MMM YYYY]	High	Firewall rule changes, network diagram, validation test	Open
A-06	F-03	Implement monitoring for unusual east-west traffic and administrative protocol use.	[Network Security Owner / SOC Manager]	[DD MMM YYYY]	Medium	Detection rules, alert tests, dashboard evidence	Open
A-07	F-04	Standardise third-party remote access using named accounts, time-bound approval, session monitoring and central logging.	[Third-Party Risk Owner]	[DD MMM YYYY]	High	Vendor access inventory, configuration evidence, session recording samples	Open
A-08	F-04	Recertify all third-party ICT access to critical or important services and remove dormant or excessive access.	[Vendor Management Lead]	[DD MMM YYYY]	High	Recertification records, removed access list, owner approvals	Open
A-09	F-05	Tune adaptive authentication and detection thresholds for externally exposed services.	[Identity Security Owner]	[DD MMM YYYY]	Medium	Policy configuration, test results, SOC alert evidence	Open
A-10	F-07	Complete inventory of privileged service accounts and define required logging, ownership and behavioural baselines.	[Application Security Owner]	[DD MMM YYYY]	Medium	Service account inventory, owner mapping, logging validation	Open
A-11	F-08	Isolate backup administration through restricted access paths, hardened workstations and dedicated privileged roles.	[Resilience Platform Owner]	[DD MMM YYYY]	Medium	Architecture update, access controls, backup admin logs	Open
A-12	F-08	Update recovery playbooks to address privileged compromise and backup platform threat scenarios.	[Business Continuity Manager]	[DD MMM YYYY]	Medium	Updated playbooks, exercise record, management sign-off	Open

Action ID	Related Finding	Action	Owner	Target Date	Priority	Evidence Required	Status
A-13	F-09	Expand phishing response automation for enrichment, search, purge, blocking and user feedback.	[Email Security Owner]	[DD MMM YYYY]	Low	Automation workflow, sample tickets, user notification evidence	Open
A-14	F-10	Update incident communications templates for critical service impact, third-party dependencies and regulatory decision points.	[Crisis Management Lead]	[DD MMM YYYY]	Low	Approved templates, exercise evidence, communications log	Open
A-15	All	Conduct targeted retesting of high-risk remediation actions and document residual risk.	[TLPT Control Team Lead]	[DD MMM YYYY]	High	Retest report, closure evidence, residual risk acceptance	Open

Immediate Risk Reduction Actions

The following actions should be completed as immediate priorities:

Priority	Action	Completion Target
1	Disable or restrict unnecessary privileged accounts identified during the TLPT.	Within [X] business days
2	Block or tighten identified lateral movement paths from corporate to support environments.	Within [X] business days
3	Enable or enhance logging for the highest-risk identity and administrative events.	Within [X] business days
4	Review third-party remote access to critical or important services.	Within [X] business days
5	Confirm backup administration access is limited to authorised personnel only.	Within [X] business days

Retesting and Validation

Remediation must be validated through a combination of evidence review, technical testing and targeted adversary emulation. Validation should confirm that controls are operating effectively in practice, not only that configuration changes have been made.

Validation Activity	Scope	Owner	Target Date
High-severity finding retest	F-01 to F-04	[TLPT Control Team Lead]	[DD MMM YYYY]
Detection engineering validation	Identity, lateral movement, exfiltration simulation	[SOC Manager]	[DD MMM YYYY]
Segmentation validation	Corporate, support and sensitive environment paths	[Network Security Owner]	[DD MMM YYYY]
Third-party access validation	Vendor remote access to critical services	[Third-Party Risk Owner]	[DD MMM YYYY]
Recovery access validation	Backup and recovery administration paths	[Resilience Platform Owner]	[DD MMM YYYY]
Management closure review	All high and medium actions	[CISO / Executive Risk Committee]	[DD MMM YYYY]

Residual Risk Management

Where remediation cannot be completed by the target date, the responsible owner must:

- Document the reason for delay.
- Define interim compensating controls.
- Assess residual risk to critical or important services.
- Obtain acceptance from the appropriate risk owner.
- Provide a revised completion date.
- Report overdue high-risk items to the relevant management committee.

Next TLPT Cycle

For designated entities, a full TLPT should be planned on a recurring three-year cycle, or earlier where there is a material change in threat profile, technology architecture, critical service delivery, outsourcing arrangements, merger activity or incident experience.

The next TLPT planning cycle should begin no later than [DD MMM YYYY] to allow sufficient time for scoping, threat intelligence procurement, provider onboarding, legal authorisation, supervisory coordination where required and safe execution.

Distribution & Confidentiality

Classification

This report is classified as **Strictly Confidential - Restricted Distribution** because it contains detailed information on attack paths, security weaknesses, defensive capabilities, third-party access arrangements and systems supporting critical or important services.

Unauthorised disclosure could materially increase the organisation's cyber risk.

Approved Distribution

Recipient Group	Access Level	Purpose
Board / Management Body	Executive summary and risk decisions	Oversight, prioritisation and risk acceptance
Executive Risk Committee	Full report or controlled extract	Remediation governance and funding decisions
CISO and cyber leadership	Full report	Security improvement and control ownership
TLPT control team	Full report	Programme management and evidence retention
SOC and incident response leads	Relevant findings and technical detail	Detection and response improvement
ICT operations and infrastructure owners	Relevant technical findings	Remediation execution
Business service owners	Impact-focused findings and actions	Service resilience accountability
Third-party risk management	Relevant third-party findings	Vendor remediation and access governance
Legal and compliance	Full report or controlled extract	Legal, contractual and regulatory assessment
Internal audit / assurance	Full report under restricted handling	Independent assurance and action tracking
External supervisory stakeholders	As approved	Regulatory engagement where required

Handling Requirements

All recipients must comply with the following handling requirements:

- Store the report only in approved restricted repositories.
- Do not forward, copy or extract content unless authorised by the document owner.
- Do not upload the report to unapproved collaboration tools, ticketing systems or external platforms.
- Use redacted extracts where full technical detail is not necessary.
- Mark all derivatives, presentations and summaries with the same or higher classification.
- Protect technical evidence, screenshots, logs and attack narratives as sensitive security information.
- Share with third parties only under approved confidentiality, legal and contractual arrangements.
- Return or securely delete copies when access is no longer required.
- Report suspected unauthorised disclosure immediately to [Security Contact / Incident Response Team].

Evidence Retention

Evidence Type	Retention Location	Minimum Retention Period	Access Owner
Final TLPT report	[Restricted repository]	[X years]	[CISO / TLPT Control Team Lead]
Red team evidence pack	[Secure evidence vault]	[X years]	[TLPT Control Team Lead]
Threat intelligence report	[Restricted repository]	[X years]	[Threat Intelligence Lead]
Rules of engagement	[Restricted repository]	[X years]	[TLPT Control Team Lead]
SOC tickets and alert evidence	[SIEM / case management system]	[X years]	[SOC Manager]
Remediation evidence	[GRC platform]	[X years]	[Risk and Control Owner]
Retest results	[Restricted repository]	[X years]	[TLPT Control Team Lead]
Management approvals	[Governance repository]	[X years]	[Corporate Secretariat / Risk Governance Lead]

Approval

Role	Name	Approval Date	Signature / Record
Senior accountable executive	[Name]	[DD MMM YYYY]	[Approval reference]
Chief Information Security Officer	[Name]	[DD MMM YYYY]	[Approval reference]
TLPT control team lead	[Name]	[DD MMM YYYY]	[Approval reference]
Head of Operational Resilience	[Name]	[DD MMM YYYY]	[Approval reference]
Legal / Compliance representative	[Name]	[DD MMM YYYY]	[Approval reference]